

Overview

Use this to link CVSS scores: <https://www.first.org/cvss/calculator/4-0>

Overview	1
C1: Weak Administrator Credentials.....	4
C1: Administrator/Root Password Reuse	5
C1: Lack of Host-Based Firewall.....	7
C1: Server-Side Template Injection in KEY website.....	9
C1: Zerologon	11

C1: Eternal Blue	13
C1: noPac.....	16
C1: Public and Unauthenticated AWS S3 Buckets	17
C1: Cleartext Credentials in Files	19
C1: JuicyPotato	21
C1: Command Injection.....	23
H1: Arbitrary File Upload.....	26
H1: XML External Entity (XXE)	27
H1: Unpatched Kernel Vulnerability - OverlayFS	30
H1: Editable Scheduled Task Running as Administrator	32
H1: PrintNightmare	34
H1: Exposed SSH Keys.....	36
H1: Stored Cross Site Scripting.....	38
H1: SQL Injection	40
H1: FTP Credential Leak.....	42
H1: UAC Disabled	44
H1: Excessive Sudo Permissions	46
H1: SMB Signing Disabled	48
Medium:	50
H1: Kerberoasting	51
M1: Server-Side Request Forgery	52
M1: Windows Defender Disabled.....	54
M1: Insecure Direct Object Reference (IDOR)	56
M1: File Disclosure.....	58
M1: Default Credentials.....	60
M1: Hard-Coded Credentials in Application	62
M1: AS-REP Roasting.....	64
M1: Local File Inclusion	66
M1: Self-Signed HTTP Certificate	68

M1: Stored XSS (no cookies).....	70
M1: Reflective XSS.....	72
I1: Excessively Privileged Application.....	73
I1: Anonymous FTP login	75
I1: SMB Share Guest Access	77
I1: Exposed API Documentation	79
I1: Outdated TLS Version.....	81

Critical:

C1: Weak Administrator Password

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1110.003: Password Spraying	
	Mitigations	M1027: Password Policies M1032: Multi-Factor Authentication	
Affected Scope			

Description

The **affected host's admin local user account** was found to be using a weak password that was successfully guessed using a dictionary-based brute force password attack. This led to the compromise of the **admin account**.

Business Impact

This vulnerability can lead to operational disruptions, as an attacker with administrative privileges on the host can disrupt systems.

Steps to Reproduce

Remediations

Team-XX recommends the following:

1. Implement and enforce a strong password policy for all accounts to ensure attackers are unable easily brute force passwords. As a baseline the following minimum password policy is recommended:
 - a. Minimum of 12 characters
 - b. At least one uppercase character, one lowercase character, one digit character, and one special symbol.
 - c. Unique passwords for each user and service to prevent password reuse
2. Implement a lockout policy to block attackers after repeated failed login attempts, preventing them from brute forcing credentials.
3. Implement multi-factor authentication to prevent access even with leaked or disclosed passwords.

References

[DigiCert - Creating Password Policy Best Practices](#)

[Linode - Fail2Ban for SSH Brute-force Protection](#)

[Palo Alto Networks - Multi Factor Authentication](#)

C1: Administrator/Root Password Reuse

Matrix Calculation		CVSS Score	Risk
Impact	Critical	10.0	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1110.003: Password Spraying T1078: Valid Accounts	
	Mitigations	M1027: Password Policies M1032: Multi-Factor Authentication	
Affected Scope			

Description

The affected host's admin local user account was found to be using the same password across multiple services and machines, including service 1 and service 2.

Business Impact

Having login access to the affected host's admin local user account allows the attacker to have administrator privileges on affected hosts, giving them access to private customer and business data, as well as modify and take down company services.

Steps to Reproduce

Remediations

Team-XX recommends the following:

1. Implement a strong password policy that prohibits reused passwords across multiple accounts or services.

2. Implement multi-factor authentication to prevent access even with reused passwords.
3. Utilize a password manager to encourage employees to avoid reusing passwords.
4. Train all users on the risk of password reuse.

References

[CISA - Password Manager Guidelines](#)

[Palo Alto Networks - Multi Factor Authentication](#)

C1: Lack of Host-Based Firewall

Matrix Calculation		CVSS Score	Risk
Impact	Critical	N/A	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK		T1595: Active Scanning	
		M1037: Filter Network Traffic	
		M1056: Pre-compromise	
Affected Scope			

Description

Multiple machines within APT's network are operating without any host-based firewalls or access control list (ACL) protections. The absence of host-based firewalls increases the attack surface, allowing for machine enumeration, unauthorized access, and exploitation of vulnerable services.

Business Impact

The lack of network protection leaves the business open for attackers to exploit any vulnerabilities on the affected machines. If they gain access to the internal network, they will be able to cause significant damage to APT's operational functionality and lead to the loss of sensitive data.

Steps to Reproduce

Step 1: Run nmap on the network to enumerate services

```
Nmap -sV -sC 10.0.0.0/24 --min-rate 5000
```

Remediations

Team-XX recommends the following:

1. Implement host-based firewalls on every machine to block unauthorized network traffic to and from internal machines.

2. Use iptables, ufw, or firewalld for Linux-based machines and use the built-in Windows Defender Firewall for Windows-based machines.
3. Consider implementing a VPN policy to allow employees to remotely access internal systems in a secure fashion.

References

[NIST Guidelines on Firewalls and Firewall Policy](#)

[Phoenixnap - Configuring Firewall with UFW on Ubuntu](#)

[Microsoft - Firewall and Network Protection](#)

C1: Server-Side Template Injection in WEBSITE

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1059: Command and Scripting Interpreter	
	Mitigations	M1038: Execution Prevention M1050: Exploit Protection M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

The affected website was found to not properly sanitize user input when rendering with the Jinja2 templating engine, making it vulnerable to a Server-Side Template Injection attack. This vulnerability allows an attacker to execute arbitrary Python code on the website server.

Business Impact

This allows an attacker to gain control of the website along with all of the data the website hosts. This can lead to sensitive data being leaked, violating certain data protection laws.

Steps to Reproduce

Step 1: Find website with search input

Step 2: Input `{{7*7}}` and find the output to be 49, showing that it executed the code

Step 3: Input

```
{{ self._TemplateReference__context.cycler.init_globals.os.popen('id').read() }}
```

to run arbitrary shell commands on the machine

Remediations

Team-XX recommends the following:

1. Utilize the templating engine's built in render function instead of render_string function to ensure that the input is properly sanitized.
2. Utilize a web application firewall (WAF) to block dangerous requests.
3. Sandbox the application and restrict its permissions to avoid remote command execution on the server.

References

[Jinja2 API Documentation for User Sanitization](#)

[Palo Alto Networks: How to Deploy Web Application Firewalls](#)

C1: Zerologon

Matrix Calculation		CVSS Score	Risk
Impact	Critical	10.0	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1210: Exploitation of Remote Services	
	Mitigations	M1051: Update Software M1016: Vulnerability Scanning	
Affected Scope			

Description

The affected host is vulnerable to CVE-2020-1472 due to an outdated version of the Netlogon Remote Protocol service. This vulnerability allows an unauthorized attacker to gain full administrative control of the domain controller, due to a cryptographic flaw in the Netlogon protocol.

Business Impact

This allows an attacker to gain control of all machines that are joined to the domain controller. This poses serious threats to data protection and sensitive information on any domain joined machine. It can also cause significant downtime to business systems, disrupting productivity.

Steps to Reproduce

- Step 1: Launch Metasploit - msfconsole
- Step 2: Search for Zerologon exploit - search zerologon
- Step 3: Load Exploit Module – use 0
- Step 4: Set LHOST to the attack machine's IP and set RHOSTS to the Domain Controller that is being attacked.
- Step 5: Run the exploit - run

Note: As this penetration test was run against the live production environment, **Team-XX** did not exploit the Zerologon vulnerability, as this attack is known to cause harm to the production environment by modifying the Domain Controller's machine account password to a blank value. Successful exploitation of this attack may cause authentication issues to occur within the domain and allow other potential attackers to log in to the Domain Controller's machine account.

Remediations

Team-XX recommends the following:

1. Apply the Microsoft security updates released after February 2021 and install them on all vulnerable Domain Controllers as soon as possible to protect against the Zerologon exploit. This patch requires an update and restart to the machine and may not be applicable if **X** is a critical system.
2. Block inbound traffic on TCP port 135 on the network firewall and monitor malicious activity in the domain controller security event logs for signs of exploitation, such as Event ID 4742.
3. Implement Windows Defender or another antivirus solution to detect and prevent common AD attacks.

References

[CrowdStrike - Zerologon Security Advisory](#)

[Microsoft - Zerologon Security Patch](#)

[NIST - CVE-2020-1472](#)

C1: EternalBlue

Matrix Calculation		CVSS Score	Risk
Impact	Critical	10.0	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1210: Exploitation of Remote Services	
	Mitigations	M1051: Update Software M1016: Vulnerability Scanning	
Affected Scope			

Description

The host is vulnerable to CVE-2017-0144 due to an outdated version of the Server Message Block (SMB) protocol, SMBv1. This vulnerability allows an unauthorized attacker to gain administrative control of the **domain controller/windows server** by sending specially crafted network packets to cause an out-of-bounds memory corruption error and run code at an elevated privilege.

Business Impact

This vulnerability allows an attacker to gain full control of the server. This poses serious threats to data protection and sensitive information stored on the machine. It can also cause significant downtime to business systems, disrupting productivity. It also allows attackers to modify the company's web pages and other key services.

Steps to Reproduce

Step 1: Launch Metasploit – msfconsole

Step 2: Search for Zerologon exploit – search eternalblue

Step 3: Load Exploit Module – use 0

Step 4: Set LHOST to the attack machine's IP and set RHOSTS to the **Windows Server/DC** machine that is being attacked.

Step 5: Run the exploit - run

Remediations

Team-XX recommends the following:

1. Apply the Microsoft security patch, MS17-010, and install it on all vulnerable Windows systems as soon as possible. This patch requires an update and restart to the computer and therefore may not be a viable option if **X** is a critical system.
2. SMBv1 should be disabled on affected machines as soon as possible and upgraded to SMBv3. The protocol is deprecated and contains known security weaknesses, including being the main cause of the EternalBlue exploit.
3. Block inbound traffic for TCP ports 139 and 445 on both the host-based and network firewall. Access to these ports should be restricted between internal network segments, allowing communication only between machines and subnets that have a legitimate need for SMB.

References

[SentinelOne - EternalBlue Security Primer](#)

[NIST - CVE-2017-0144](#)

C1: noPac

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1068: Exploitation for Privilege Escalation	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

An attacker with access to any standard domain user can elevate their privileges to Domain Administrator by exploiting flaws in the Kerberos protocol and the Security Account Manager (SAM) due to an issue with name checking. This vulnerability allows an attacker to gain administrative control over the Domain Controller. This exploit takes advantage of two publicly disclosed vulnerabilities, CVE-2021-42278 and CVE-2021-42287.

Business Impact

Successful exploitation leads to a full domain compromise, with the attacker gaining complete control over the entire Active Directory forest. This enables an attacker to steal all credentials, deploy malware, exfiltrate or destroy sensitive data, and take over all domain-joined systems and services running on those systems.

Steps to Reproduce

Step 1: Use the noPac exploit found on Github: <https://github.com/Ridter/noPac>

Step 2: Input valid credentials and get a domain administrator shell.

OR

Step 1: Create a new machine account on the domain

Step 2: Rename the machine account's SAMAccountName to match a domain controller's name, without the ending '\$'.

Step 3: Request a Kerberos Ticket Granting Ticket (TGT) for the account

Step 4: Use this ticket to request a service ticket, which will have Domain Admin privileges, allowing for a takeover of the Domain Controller.

Remediations

Team-XX recommends the following:

1. Install security updates released by Microsoft in November 2021 or later for all Domain Controllers.
2. Change the Active Directory attribute MS-DS-MachineAccountQuota to zero to prevent non-privileged users from adding new machine accounts.
3. Implement Windows Defender or another Antivirus solution to detect and prevent common attacks.

References

[Secureworks - noPac Vulnerability Overview](#)

[Microsoft - CVE-2021-42278](#)

[Microsoft - CVE-2021-42287](#)

C1: Public and Unauthenticated AWS S3 Buckets

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1530: Data from Cloud Storage	
	Mitigations		
Affected Scope			

Description

The WordPress server contains an outdated version of the File Manager plugin allowing an unauthenticated user to execute arbitrary code. Known CVE: CVE-2026-12345.

Business Impact

This outdated plugin presents a significant risk, allowing attackers to execute arbitrary code on the WordPress Server which can lead to complete compromise of the WordPress server and its backend.

Steps to Reproduce

Remediations

Team-XX recommends the following:

1. Update the known vulnerable plugin or completely removing the plugin if it is not actively in use. APTCL should have continuous patching of WordPress plugins and themes to keep up to date with security updates to minimize the risk of a successful attack.

References

C1: Cleartext Credentials in Files

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.2	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:N/SC:H/SI:H/SA:N	
MITRE ATT&CK	Techniques	T1552: Unsecured Credentials - Credentials in Files	
	Mitigations	M1047: Audit M1022: Restrict File and Directory Permissions	
Affected Scope			

Description

System/Application contains the credentials of other users stored in plaintext, located in a file on the **Desktop**.

Business Impact

Having insecurely stored credentials on the system without any proper form of encryption can lead to personal information leakage and potential privilege escalation depending on the privileges of the compromised accounts. Since credential reuse is also a common vulnerability, an attacker could potentially move laterally across the network and compromise other accounts as well.

Steps to Reproduce

Remediations

Team-XX recommends the following:

1. All sensitive user credentials should be securely stored in appropriate, protected locations and never in unsecured files.
2. All sensitive data should be encrypted at rest to protect confidentiality, integrity, and prevent unauthorized access.

References

[NIST - Data Confidentiality: Identifying and Protecting Assets Against Data Breaches](#)

C1: JuicyPotato

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1068: Exploitation for Privilege Escalation	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

JuicyPotato is a Windows privilege escalation exploit that abuses the “SeImpersonate” and “SeAssignPrimaryToken” privileges to escalate from a **local service account** to System. The exploit impersonates Component Object Models (COM) to create new processes and assign its token to have system privileges.

Business Impact

This vulnerability allows an attacker to elevate their privileges to SYSTEM from any low privileged user. With SYSTEM permissions, the attacker can access any confidential data or stored credentials on the machine, deface any running services, and move laterally to other machines that interact with the affected machine.

Steps to Reproduce

Step 1: Check if the **current service account** has “SeImpersonate” and “SeAssignPrimaryToken” privileges:

```
*codeblock? whoami /priv
```

Step 2: Transfer JuicyPotato.exe to the target system from

<https://github.com/ohpe/juicy-potato>

Step 3: Find a working CLSID for the target OS version from the JuicyPotato repository

Step 4: Execute the exploit

```
JuicyPotato.exe -l 1337 -p C:\Windows\System32\cmd.exe -a "/c whoami > C:\output.txt" -t * -c {CLSID}
```

Step 5: Check the output file to confirm SYSTEM-level access:

```
type C:\output.txt
```

Expected output: nt authority\system

Remediations

Team-XX recommends the following:

1. Apply the latest Windows security patch, which will address several Potato-style exploits.
2. Service accounts should not be given the "SeImpersonate" or "SeAssignPrimaryToken" privileges unless necessary.
3. If DCOM is not necessary, it should be disabled or removed.
4. In systems where these protections are not viable, the network should be sufficiently segmented to prevent lateral access and suspicious impersonation techniques should be properly logged.
5. Implement Windows Defender or another Antivirus solution to detect and prevent common AD attacks.

References

[Microsoft Learn - Behavior Blocking Containment, Juicy Potato](#)

C1: Token Impersonation Privilege Escalation

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1068: Exploitation for Privilege Escalation T1134: Access Token Manipulation - Token Impersonation/Theft	
	Mitigations	M1026: Privileged Account Management	
Affected Scope			

Description

Token impersonation on a Windows Server allows an attacker to steal other users' tokens from system memory. This allows an attacker with unauthorized access to a low-privileged account with the `SelImpersonate` privilege to laterally move to `NT AUTHORITY\SYSTEM` or another user account, allowing an attacker to completely compromise the server.

Business Impact

Given an attacker has access to a low-privileged account on the Windows Server, this vulnerability allows them to pivot to a higher authority on the system. This allows the attacker to gain full control over the server, resulting in a complete compromise of the confidentiality, integrity, and availability of sensitive information and services on the network.

Steps to Reproduce

- Step 1: Obtain a Meterpreter shell on the vulnerable system
- Step 2: List the available Delegation Tokens using `list_tokens -u`
- Step 3: Impersonate `NT AUTHORITY\SYSTEM` using `impersonate_token "NT AUTHORITY\SYSTEM"`
- Step 4: Use the `shell` command to get a shell as the elevated user

Step 5: Type *whoami* to verify elevated privileges

Remediations

Team-XX recommends the following:

1. Use Group Policy to restrict SeImpersonatePrivilege to only necessary, high-privileged users. Remove impersonated privileges from all service accounts and users that do not explicitly require it.
2. Configure LSA Protection via Group Policy and enable Protected Process Light (PPL) to protect LSASS process memory from unauthorized access.

References

[Microsoft Learn - Access Tokens](#)

[Microsoft Learn - Configure LSA Protection](#)

C1: Command Injection

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application T1203: Exploitation for Client Execution	
	Mitigations	M1038: Execution Prevention M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

Command injection allows an attacker to execute arbitrary operating system (OS) commands on the system running the application. This occurs when the application uses user-supplied data in a command that is then executed by the system shell.

Business Impact

A successful command injection attacker could lead to a compromise of the server hosting the application. They could view, modify, and steal sensitive information stored on the server and use the server to move laterally across the network.

Steps to Reproduce

Step 1: Identify the application feature **X** that passes user input to a system command.

Step 2: In the input, enter a valid value followed by a command separator (**X**).

Step 3: Append the OS command **'whoami'** after the separator and submit the input

Step 4: View the output **X** which will confirm the vulnerability.

Remediations

Team-XX recommends the following:

1. Avoid OS command execution and refactor the server code to use APIs such as calling a binary directly instead of running shell code.
2. If calling OS commands is unavoidable, use a whitelist of approved characters or blacklist of disapproved characters and reject any input that fails the check.
3. Utilize a web application firewall (WAF) to block dangerous requests.
4. Sandbox the application and restrict its permissions to avoid remote command execution on the server.

References

[OWASP - Command Injection](#)

[PortSwigger - What is command injection?](#)

[Palo Alto Networks: How to Deploy Web Application Firewalls](#)

C1: Weak Database Password

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1110.003 - Brute Force: Password Spraying T1110.001 - Brute Force: Password Guessing	
	Mitigations	M1027: Password Policies	
Affected Scope			

Description

The Database password was found to be weak and easily guessable through brute force attacks, allowing an attacker to have control over the database.

Business Impact

This vulnerability can lead to operational disruptions and data leakage as an attacker that gains access to the database can view, modify, delete, and add arbitrary data to the database.

Steps to Reproduce

Step 1: Run a brute force attack systematically guessing passwords.

Remediations

Team-XX recommends the following:

1. Implement and enforce a strong password policy for all accounts to ensure attackers are unable to easily brute force passwords. As a baseline the following minimum password policy is recommended:
 - a. Minimum of 12 characters
 - b. At least one uppercase character, one lowercase character, one digit character, and one special symbol.

- c. Unique passwords for each user and service to prevent password reuse
- 2. Implement a lockout policy to block attackers after repeated failed login attempts, preventing them from brute forcing credentials.
- 3. Implement multi-factor authentication to prevent access even with leaked or disclosed passwords.

References

[DigiCert - Creating Password Policy Best Practices](#)

C1: ADCS Misconfigured Certificate Template – ESC1

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.4	Critical
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1648: Steal or Forge Authentication Certificates	
	Mitigations	M1015: Active Directory Configuration M1047: Audit	
Affected Scope			

Description

ESC1 is a misconfiguration in a certificate template within APT's Active Directory Certificate Services (ADCS). This vulnerable template allows a low privileged user to authenticate as the domain administrator, gaining privileged access to APT's domain.

Business Impact

Successful exploitation of **ESC1** will allow threat actors to exfiltrate sensitive data from the domain and disrupt cruise operations by taking down critical domain systems, possibly leading to a loss of life.

Steps to Reproduce

Step 1: Identify vulnerabilities within the certificate templates:

```
certipy find -username john@corp.local -password Passw0rd -dc-ip 172.16.126.128
```

Step 2: Request a certificate to impersonate the Administrator user:

```
certipy req -username john@corp.local -password Passw0rd! -target-ip ca.corp.local -ca 'corp-CA' \ -template 'ESC1' -upn 'administrator@corp.local'
```

vStep 3: Use the certificate to log in as the Administrator user:certipy auth -pfx administrator_cert.pfx -dc-ip 10.0.0.5

Remediations

Team-XX recommends the following:

1. Disable the “Supply in the Request” Configuration.
2. Enable the “CA Manager Approval” requirement.
3. Remove any Extended Key Usage (EKU) properties that enable user authentication.
4. Restrict enrollment permissions to only trusted administrative or service accounts.
5. Conduct regular audits of the ADACS system to identify any future misconfigurations.

References

[Microsoft - ESC1 Security Assessment and Prevention](#)

[CrowdStrike - Investigating ESC1](#)

C1: Lack of Multi-Factor Authentication

Matrix Calculation		CVSS Score	Risk
Impact	Critical	N/A	Critical
Likelihood	Medium		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1110: Brute Force	
	Mitigations	M1032: Multi-Factor Authentication	
Affected Scope			

Description

The APT network does not implement Multi-Factor Authentication (MFA) for users on any service. As a result, if an attacker can discover an account password, they will gain access to any service on the network without further authorization.

Business Impact

The absence of MFA significantly increases the danger of unauthorized access to APT's network. Successful compromise of an account can lead to data exfiltration, service disruption, and jeopardization of operational integrity. A privileged account being compromised can endanger the entire network, including critical cruise operations, leading to severe safety risks and possible loss of life.

Steps to Reproduce

Step 1: Locate a user's credentials

Step 2: Authenticate with the user's credentials and notice that there is no additional verification required.

Remediations

Team-XX recommends the following:

1. Implement multi-factor authentication, such as mobile authenticator verification or time-based one-time passwords (TOTP), for all user accounts, prioritizing privileged accounts and any publicly available systems.
2. Monitor and audit authentication events for failed MFA verification or MFA bypass attempts.

References

[Palo Alto Networks - Multi Factor Authentication](#)

C1: Insecure Cookie Deserialization

Matrix Calculation		CVSS Score	Risk
Impact	Critical	9.3	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public Facing Application	
	Mitigations	M1048: Application Isolation and Sandboxing M1054: Software Configuration	
Affected Scope			

Description

The affected website deserializes pickled Python objects for cookie-based authentication of users. This allows an attacker to craft serialized payloads to trigger code execution on the host server upon deserialization.

Business Impact

This vulnerability can lead to operational disruption on the host server and a loss of critical data, as attackers can have the ability to perform arbitrary, remote code execution of the backend server.

Steps to Reproduce

- Step 1: Use the web browser's developer tools to extract the cookie.
- Step 2: Craft a malicious pickled cookie that contains a reverse shell payload.
- Step 3: Modify the browser cookie with the developer tools and send a new request to web browser.
- Step 4: Run a Netcat Listener and wait for a reverse shell to spawn.

Remediations

Team-XX recommends the following:

1. Replace insecure pickled based cookie formats with cryptographically signed or encrypted alternatives such as JSON Web Tokens (JWT) or Flask's builtin session cookies.
2. Isolate the web application in a docker container to reduce impact if an attacker can achieve code execution on the target server

References

[Portswigger - Insecure Deserialization](#)

C1: PetitPotam

Matrix Calculation		CVSS Score	Risk
Impact	Critical	10.0	Critical
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	
MITRE ATT&CK	Techniques	T1190: Exploit Public Facing Application	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

The affected host is vulnerable to CVE-2021-36942 (PetitPotam). This vulnerability forces the Windows host to authenticate to an attacker-controlled NTLM server, allowing them to relay the authentication request to compromise the domain controller.

Business Impact

This vulnerability can lead to operational disruptions, as an attacker can take control of the domain, taking down critical infrastructure that APT needs for its business and cruise operations.

Steps to Reproduce

Step 1: Start an SMB server:

```
Impacket-smbserver share . -smb2support
```

Step 2: Run the PetitPotam attack.

Step 3: Capture the authentication request on the SMB server.

Remediations

Team-XX recommends the following:

1. Disable NTLM authentication on the Domain Controller.
2. Disable NTLM authentication on ADCS servers using group policy.

3. Install the latest Microsoft security updates which will address NTLM relaying issues.
4. Enable SMB Signing to prevent NTLM relaying.

References

[Microsoft - Mitigating NTLM Relay Attacks on ADCS](#)

[Rapid7 - PetitPotam Security Advisory](#)

High

H1: Arbitrary File Upload

Matrix Calculation		CVSS Score	Risk
Impact	High	8.7	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1505.003: Server Software Component - Web Shell T1204.002: User Execution - Malicious File	
	Mitigations	M1048: Application Isolation and Sandboxing M1050: Exploit Protection	
Affected Scope			

Description

The **Avatar Image Upload** allows users to upload any arbitrary file type. This allows users to upload malicious code as their avatar picture, which will be executed on the backend server when uploaded and rendered.

Business Impact

This vulnerability gives attackers remote code execution on the backend server. This can lead to system compromise if attackers execute a reverse shell script, which compromises the integrity of the web server.

Steps to Reproduce

- Step 1: Navigate to the **Edit Profile** page and select **avatar image**
- Step 2: Upload a PHP reverse shell as the **avatar image**
- Step 3: Start a Netcat listener
- Step 4: Click save to upload the reverse shell
- Step 5: Observe the opened shell on the Netcat listener

Remediations

Team-XX recommends the following:

1. Enforce file type restrictions through a whitelist, such that only common image types should be allowed, such as .img, .jpg, .png. Disallow all other file types.
2. Set the permission of user uploaded files to be non-executable.
3. Containerize the application to minimize impact in case of abuse.
4. Utilize a web application firewall to filter malicious uploads.
5. Sandbox the application and restrict its permissions to avoid remote command execution on the server.

References

[Pentestmonkey: PHP Reverse Shell](#)

[OWASP - Unrestricted File Upload](#)

[Palo Alto Networks: How to Deploy Web Application Firewalls](#)

H1: XML External Entity (XXE)

Matrix Calculation		CVSS Score	Risk
Impact	High	8.8	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application T1005: Data from Local System	
	Mitigations	M1038: Execution Prevention M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

The **application** allows attackers to control parts of the processed XML data. The attacker can then inject malicious XML, containing external entities that can be used to access local files, perform denial-of-service attacks, and execute server-side request forgery (SSRF) attacks.

Business Impact

An attacker can leverage this vulnerability to exfiltrate confidential data stored in files from the machine, as well as take down services for long periods of time through XML bomb-based denial-of-service attacks.

Steps to Reproduce

Step 1: Find an editable XML request being sent to the server

```
<?xml version="1.0" encoding="UTF-8"?>
<stockCheck><productId>381</productId></stockCheck>
```

Step 2: Inject an XML external entity that can be used to read any file on the system

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
```


<stockCheck><productId>&xxe;</productId></stockCheck>

Remediations

Team-XX recommends the following:

1. Disable external entities in XML parsers, preventing attacks from occurring.
2. Perform input validation, specifically disallowing !DOCTYPE declarations.
3. Use safe parsing libraries built into all common web frameworks.
4. Install a web application firewall (WAF) to block dangerous XML requests.
5. Sandbox the application and restrict its permissions to limit the impact of remote command execution on the server.

Resources

[OWASP - XXE Explained](#)

[OWASP - XXE Prevention Cheatsheet](#)

[Palo Alto Networks: How to Deploy Web Application Firewalls](#)

H1: File Permission Enabled on MySQL Server

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application T1005: Data from Local System	
	Mitigations	M1038: Execution Prevention M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

The **SQL user** has the FILE permission enabled, allowing an attacker to read and write to files on the server. An attacker could potentially leverage this to achieve remote code execution (RCE) through a web shell or writing to another file that gets executed.

Business Impact

An attacker can leverage this vulnerability to exfiltrate confidential data stored in files from the machine, overwrite important files, as well as potentially achieve remote code execution on the server.

Steps to Reproduce

Step 1: Login to the SQL server

Code block: `mysql -u root -p`

Step 2: Observe the FILE permission being enabled when running the following command:

```
SELECT grantee, privilege_type FROM information_schema.user_privileges  
WHERE grantee = "currentuser"
```

Remediations

Team-XX recommends the following:

1. Audit user permissions and disable any unnecessary permissions, to prevent low privileged users from having access to run arbitrary commands on the backend server.
2. If FILE permission is required, make sure `secure_file_priv` is set to restrict what files the SQL user can read and write to.

Resources

[MySQL - Privileges Documentation](#)

H1: Unnecessary Administrator Privileges for All Users

Matrix Calculation		CVSS Score	Risk
Impact	High	8.6	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1078: Valid Accounts	
	Mitigations	M1026: Privileged Account Management M1018: User Account Management	
Affected Scope			

Description

All users on the system currently possess administrative privileges. This allows any user on the system to be able to modify key parts of the system, as well as view all sensitive information present on the system.

Business Impact

The system directly violates the Principle of Least Privilege by allowing non-administrator users to have administrative access to the system. This compromises confidentiality and integrity, as any user can view and manipulate sensitive data on the system. This also enables an attacker to immediately have administrator access if gaining unauthorized access to any user on the system.

Steps to Reproduce

Step 1: List all users with Administrator privileges using 'net localgroup administrators'.

Step 2: Check for administrative access.

Remediations

Team-XX recommends the following:

1. Audit user permissions so that non-administrator users do not have administrative access to the system.
2. Implement administrative access policies to ensure a clear procedure that allows only required users to have admin privileges on the system.
3. Continuously update and audit user permissions to avoid permission creep over time.

Resources

[CrowdStrike - Principle of Least Privilege](#)

[CISA - Weak User Management and Security Controls](#)

H1: Unpatched Kernel Vulnerability - OverlayFS

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1608: Exploitation for Privilege Escalation	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

The affected host is running an outdated kernel vulnerable to CVE-2021-3493, OverlayFS. This exploit allows an attacker to escalate privileges from a low-privileged user to root by smuggling an SUID binary from a lower directory to an upper directory, with the use of OverlayFS as an intermediary.

Business Impact

An attacker with low-privileged access to the system can take over the root user, giving them complete control over the system. With this, they can enumerate and search for more sensitive information, or modify or turn off services running on the machine.

Steps to Reproduce

Step 1: Downloaded the exploit from: <https://github.com/briskets/CVE-2021-3493>

Step 2: Upload the exploit C code to the machine via SCP using the **USER** user

Step 3: Once on the machine, compile the exploit code using gcc

Step 4: Run the executable file to obtain root access

Remediations

Team-XX recommends the following:

1. All machines should be updated to the latest version of the kernel available, as exploits such as these are fixed rapidly within days of discovery.
2. An auto-patching solution can automate the patching process, ensuring all systems are up to date without manual intervention.
3. Note that an Ubuntu or Debian based system is likely to be vulnerable if it has a kernel version below 6.2, which can be verified with the command `uname -r`.

References

[NIST - CVE-2023-0386](#)

[WIZ - Ubuntu Overlay Vulnerability Explanation](#)

H1: Editable Scheduled Task Running as Administrator

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1053.005: Scheduled Task/Job - Scheduled Task	
	Mitigations	M1022: Restrict File and Directory Permissions M1026: Privileged Account Management	
Affected Scope			

Description

The machine contains a scheduled task that runs a script controlled by **USER**. This scheduled task runs as Administrator, which can then be modified by a low privileged user to escalate to the Administrator account.

Business Impact

An attacker can change the intended purpose of the scheduled task, which will impact business operations. The attacker can also use the scheduled task to gain Administrator access, and gain Administrator access to the system.

Steps to Reproduce

- Step 1: Locate the file in the files of the **USER** user
- Step 2: View permissions of the file to see that it is run as Administrator
- Step 3: Modify the batch file to run a reverse shell when executed
- Step 4: Create a listener and wait for a connection when the scheduled task runs.

Remediations

Team-XX recommends the following:

1. All scheduled tasks that must be run as Administrator should only be editable by the Administrator account.

2. If a scheduled task does not need administrative privileges to run, it should not have admin privileges to follow the Principle of Least Privilege and prevent privilege escalation attempts.
3. Centralize scheduled task management via Group Policy to allow for deployment and tracking of scheduled tasks centrally.

References

H1: PrintNightmare

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1608: Exploitation for Privilege Escalation	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

MACHINE is vulnerable to the PrintNightmare exploit (CVE-2021-1675) which abuses a set of vulnerabilities in Windows Print Spooler to allow an attacker to escalate their privileges from a low-level user to Administrator. An attacker with a low-privileged local account can install a malicious print driver to escalate privileges to Administrator.

Business Impact

An attacker could gain complete control of the machine, allowing them to shut down critical services running on the machine, see sensitive documents stored on it, and also use the machine to pivot and attack other machines.

Steps to Reproduce

- Step 1: Log into the machine as **USER**
- Step 2: Download the PowerShell POC exploit from <https://github.com/calebstewart/CVE-2021-1675>
- Step 3: Import the cve-2021-1675.ps1
- Step 4: Run Invoke-Nightmare
- Step 5: Log in as the new user

Remediations

Team-XX recommends the following:

1. Apply at least Microsoft patch KB5004945 mitigating the PrintNightmare vulnerability.
2. An auto-patching solution can automate the patching process, ensuring all systems are up to date without manual intervention.
3. Printspooler should be disabled on machines that do not need printing access for attack surface reduction.
4. Implement Windows Defender or another Antivirus solution to detect and prevent common AD attacks.

References

[CISA - PrintNightmare Security Advisory](#)

[Microsoft - PrintNightmare Security Patch](#)

H1: Exposed SSH Keys

Matrix Calculation		CVSS Score	Risk
Impact	High	8.6	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1552.004: Unsecured Credentials - Private Keys	
	Mitigations	M1022: Restrict File and Directory Permissions M1047: Audit	
Affected Scope			

Description

The **machine** contains the private SSH key for **the root user** to the following machines:

Business Impact

If an attacker gains unauthorized access to this machine, they can pivot to further machines as root. **ADD MORE**

Steps to Reproduce

Step 1: Log into the machine as **USER**

Step 2: Enumerate the file system and discover the private ssh key in **the following directory**.

Step 3: Use the found private key to log into **further machines** as root.

Remediations

Team-XX recommends the following:

1. All SSH keys for Administrator and root should be password protected. This ensures low-privilege accounts cannot utilize these keys to gain full-system access and pivot to more of the network.
2. The leaked private keys should be disabled and removed from all APT systems.

3. Future SSH keys should be stored in a more secure manner, such as inside internal private servers that are not accessible by low-privileged user accounts.

References

[NIST - Recommendation for Key Management](#)

[SSH Academy - NIST 800-53 Controls for SSH Key Access and Storage](#)

H1: Stored Cross Site Scripting

Matrix Calculation		CVSS Score	Risk
Impact	High	8.8	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1189: Drive-by Compromise T1059.007: Command and Scripting Interpreter - JavaScript T1539: Steal Web Session Cookies (Delete If Not Used)	
	Mitigations	M1021: Restrict Web Based Content M0818: Validate Program Inputs	
Affected Scope			

Description

Unsanitized user input is stored on the server and is sent to the client as HTML when viewed, allowing an attacker to run arbitrary JavaScript code on the client. This allows an attacker to upload a malicious script as user input, which when rendered by **another user or APT Admin**, will send the cookie to the attacker, leading to session hijacking.

Business Impact

This allows a malicious actor to manipulate other client sessions to render JavaScript code that can be used to steal session cookies, render attacker-controlled HTML, and alter the functionality of the website for other users, leading to reputation damages and user account compromise.

Steps to Reproduce

Step 1: Create a post with the following payload `<script>alert(1)</script>`

Step 2: View the post

Remediations

Team-XX recommends the following:

1. Validate and normalize all user input on the server with a whitelist if applicable. Always encode output and never store raw HTML or JavaScript from untrusted user input without sanitization.
2. Implement a Web Application Firewall to block malicious JavaScript payloads.
3. Utilize a strict Content Security Policy to restrict JavaScript sources.
4. Mark session cookie configurations such as *HttpOnly*, *Secure*, and *SameSite=Strict* to protect cookies from exfiltration.

References

[Mozilla - Secure Cookie Configurations](#)

[Portswigger - Cross Site Scripting Prevention](#)

H1: SQL Injection

Matrix Calculation		CVSS Score	Risk
Impact	High	8.8	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1005: Data from Local System T1213: Data from Information Repositories	
	Mitigations	M1048: Application Isolation and Sandboxing M0818: Validate Program Inputs	
Affected Scope			

Description

The **X** parameter on the **/[page]** is vulnerable to **X** and **X** based SQL injection. This can be used to access the **X** database stored on **X** machine.

Business Impact

This allows an adversary to have the ability to modify the SQL statement to view the contents of any entry across the entire database, including in other tables. This could potentially allow access to confidential user data such as **usernames, hashes, passwords, personal information, and confidential business information.**

Steps to Reproduce

Step 1: Using a tool such as Burp Suite, capture a request of **X (Website, Login Request, Search Request, etc.)**

[Picture of Burp Suite Capture]

Step 2: Using a tool like SQLMap, attach the request and get the database name or other database and table information.

Command: **[SQLMap Command]**

[Picture of SQLMap Command Completed]

Remediations

Team-XX recommends the following:

1. Update the source code to include proper input sanitization when handling the **X** parameter to prevent user input from overwriting the intended SQL statement.

References

[OWASP - SQL Injection Overview](#)

[OWASP - SQL Injection Prevention Cheat Sheet](#)

H1: MSSQL PowerShell Command Execution

Matrix Calculation		CVSS Score	Risk
Impact	High	8.6	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:A/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1059: Command and Scripting Interpreter	
	Mitigations	M1038: Execution Prevention, Mitigation	
Affected Scope			

Description

The MSSQL Server has xp_cmdshell enabled, a feature which is disabled by default. This allows for an attacker to run PowerShell commands from the SQL Server environment, giving an attacker arbitrary PowerShell command execution as **NT Authority\SYSTEM**.

Business Impact

An attacker that has gained unauthorized access to the MSSQL Server can run arbitrary commands as a **highly privileged user** on the backend Windows system. This allows an attacker to run a reverse shell script that gives them access to the Windows server, gaining complete control and access to sensitive data and internal systems.

Steps to Reproduce

Step 1: Log into the MSSQL Server with previously found credentials.
Step 2. Run xp_cmdshell whoami to verify privilege level and that xp_cmdshell is enabled
Step 3. Use xp_cmdshell to run a PowerShell reverse shell to gain access to the Windows server.

Remediations

Team-XX recommends the following:

1. If xp_cmdshell is not required for normal business operations, use sp_configure or Policy Based Management to disable the feature.
2. If this feature is required, use the sp_xp_cmdshell_proxy_account system to configure xp_cmdshell to use a least-privileged account that has minimal risk of abuse.
3. Ensure strong credentials are in place to access the MSSQL Server, to ensure only authorized users can access the server.

References

[Microsoft - XP CMDSHELL](#)

H1: FTP Credential Leak

Matrix Calculation		CVSS Score	Risk
Impact	High	8.8	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1552.001 - Unsecured Credentials: Credentials in files	
	Mitigations	M1047: Audit M1027: Password Policies	
Affected Scope			

Description

The FTP server permitting anonymous logon hosts sensitive information, including plaintext credentials for system users allowing an attacker to gain a foothold on the network through the leaked credentials.

Business Impact

An attacker can use the exposed credentials to gain unauthorized access to other systems and applications within the network, potentially leading to a full system compromise. This can result in sensitive data being stolen, financial loss, and reputational damage.

Steps to Reproduce

Step 1: Log into the FTP server with anonymous access
Step 2: Recursively list the files on the server to identify sensitive files with 'ls -R'.
Step 3: Download any suspicious files using the get command.
Step 4: Examine the contents of the downloaded file **X** and confirm the presence of plaintext credentials.

Remediations

Team-XX recommends the following:

1. Disable anonymous access by modifying the FTP server configuration file to disallow anonymous logins if sensitive/confidential information is stored on the server.
2. Audit and remove any sensitive files from the FTP Server directories. Implement a strong policy against storing such information on network shares.
3. Implement firewall policies to block the FTP server from being accessible from the outside internet and only from trusted internal network segments.

References

[Cerberus - How to Secure an FTP Server](#)

[Phoenixnap - Configuring Firewall with UFW on Ubuntu](#)

H1: UAC Disabled

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1548.002: Abuse Elevation Control Mechanism - Bypass User Account Control	
	Mitigations	M1052: User Account Control	
Affected Scope			

Description

The machine has User Account Control (UAC) disabled or configured to the lowest setting, "Never Notify". UAC is a Windows security component that prevents unauthorized changes by requiring administrative verification for actions affecting the operating system. With UAC disabled, any user can execute code with administrative privileges without verification.

Business Impact

An attacker who gains low-privilege access can escalate their privileges to a full administrator. This leads to a full system compromise, allowing attackers to steal sensitive data and move laterally to compromise other systems on the network.

Steps to Reproduce

Step 1: Log into the affected Windows machine with a user.

Step 2: Attempt to open PowerShell as administrator and observe that it opens immediately without a UAC prompt.

Remediations

Team-XX recommends the following:

1. Enable UAC and set it to the default “Notify me only when apps try to make changes to my computer” or higher.
2. Set the correct UAC settings via Group Policy Objects (GPO) to enforce it across a domain environment, preventing users from disabling it and ensuring a consistent security posture.

References

[Microsoft - User Account Control Overview](#)

H1: Excessive Sudo Permissions

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1548.003 - Abuse Elevation Control Mechanism: Sudo and Sudo Caching	
	Mitigations	M1028: Operating System Configuration M1026: Privileged Account Management	
Affected Scope			

Description

The **USER** is able to use **BINARY** with Sudo permissions. This can be abused to elevate privilege from a non-privileged user to root.

Business Impact

This allows an adversary with access to the system who gained unauthorized access to the **USER** account to obtain root permissions on the system. This allows the attacker to take down or modify the systems hosted on the machine, and access any sensitive information stored on it.

Steps to Reproduce

Step 1: As a low-privileged user, run `sudo -l` to view sudo privileges.
Step 2: Go to [GFTOBins](#) and drop the commands here
Step 3: Run `whoami` to view newly elevated privilege as root

Remediations

Team-XX recommends the following:

1. **BINARY** permissions be removed from the user if the Sudo permission is unnecessary.

2. Never grant broad *ALL* or wildcard command permissions, constrain allowed commands to a single absolute path and to only exact subcommands required.
3. Require authentication and remove *NOPASSWD* so actions are accountable and require user credentials.
4. ATP should implement the Principle of Least Privilege to ensure that each user does not have more permissions than absolutely necessary for business operations.

References

[Red Hat - Managing Sudo Access](#)

[CrowdStrike - Principle of Least Privilege](#)

H1: SMB Signing Disabled

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:A/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1021.002: Remote Services - SMB/Windows shares T1557.001: Adversary in the Middle - LLMNR/NBT-NS Poisoning and SMB Relay	
	Mitigations	M1037: Filter Network Traffic M1042: Disable or Remove Feature or Program	
Affected Scope			

Description

Team-XX discovered the listed hosts have SMB signing disabled. This leaves the machines vulnerable to an NTLM relay attack, potentially allowing attackers to steal credentials and fake authentication to certain Windows services.

Business Impact

This allows an adversary to compromise a service account, which can lead to a data breach, lateral movement across the network, and potential domain compromise if the account has high privileges. They can also cause severe operational disruption by modifying the service that the service account controls.

Steps to Reproduce

Step 1: Use Responder to create an NTLM server that can intercept authentication requests.

Remediations

Team-XX recommends the following:

1. Enable SMB Signing across all machines on APT's network through the Computer Group Policy.

-
2. If an application requires SMB signing to be disabled, disable NTLM authentication.

References

[Microsoft - Configure SMB Signing](#)

H1: Unencrypted HTTP Traffic

Matrix Calculation		CVSS Score	Risk
Impact	High	7.1	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:P/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T0842 - Network Sniffing	
	Mitigations	M0808 - Encrypt Network Traffic	
Affected Scope			

Description

The web application was found to be transmitting sensitive data over unencrypted HTTP traffic, which allows an attacker on the same network to intercept, read, and modify the traffic in transit. If a user enters any login credentials, session tokens, or personal data, it is sent in cleartext and is vulnerable to network sniffing.

Business Impact

An attacker can exploit this vulnerability by conducting a man-in-the-middle (MITM) attack, leading to the compromise of user accounts and theft of sensitive information. This can result in unauthorized access to systems, data breaches, financial loss, and damage to APT's reputation.

Steps to Reproduce

Step 1: Use a network sniffing tool like Wireshark to capture network traffic.
Step 2: Filter the captured traffic for the HTTP protocol.
Step 3: Interact with the web application and observe the captured packets to view the sensitive data being transmitted in cleartext.

Remediations

Team-XX recommends the following:

1. Enforce HTTPS by implementing TLS (Transport Layer Security) across the entire website to encrypt all data transmitted between client and server.
2. Also implement secure cookies by ensuring all session cookies have the "Secure" flag.

References

[OWASP - Insufficient Transport Layer Protection](#)

H1: Lack of Web Application Firewall

Matrix Calculation		CVSS Score	Risk
Impact	High	N/A	High
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application	
	Mitigations	M1037: Filter Network Traffic M1050: Exploit Protection	
Affected Scope			

Description

Web servers on APT's network lack any form of web application firewalls (WAFs) to protect websites from attacks. The absence of a web application firewall increases the chances that a vulnerable web application will be exploited by a threat actor using common website exploitation techniques. Implementing a WAF preemptively stops many other web application exploits.

Business Impact

The lack of web application protection leaves APT open to attacks on web apps, leading to a loss of sensitive customer data and potentially cruise disrupting operations.

Steps to Reproduce

N/A

Remediations

Team-XX recommends the following:

1. Deploy web application firewalls on all servers that currently host websites, prioritizing those that are publicly accessible.

References

[Palo Alto Networks - How to Deploy Web Application Firewalls](#)
[Oracle - Web Application Firewall Policies](#)

H1: Lack of Network Segmentation

Matrix Calculation		CVSS Score	Risk
Impact	High	N/A	High
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1210: Exploitation of Remote Services	
	Mitigations	M1030: Network Segmentation	
Affected Scope			

Description

Multiple hosts are reachable across a flat network without any zone-based controls separating them. A successful compromise of a single host grants attackers the ability to pivot into all adjacent systems in APT's network.

Business Impact

If an attacker can compromise a single host on the internal network, they then have the ability to pivot to all other systems on the network. This can allow an attacker to perform a full network takedown, causing massive financial, operational and reputational damage. If a single host is vulnerable, an attacker can leverage it to infect all other systems on the network.

Steps to Reproduce

N/A

Remediations

Team-XX recommends the following:

1. Implement Network Segmentation to isolate publicly accessible applications from critical systems that are needed for the cruise's operational functionality
2. Apply least privileged network access to only allow required communications between machines to take place

3. Regularly audit segmentation controls through network scans and firewall reviews.

References

[Nordlayer - Network Segmentation Best Practices](#)

[Splunk - Guide to Network Segmentation](#)

H1: Password in User Description

Matrix Calculation		CVSS Score	Risk
Impact	High	8.6	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:L/SI:L/SA:L	
MITRE ATT&CK	Techniques	T155: Credentials from Password Stores	
	Mitigations	M1047: Audit M1027: Password Policies	
Affected Scope			

Description

The password for **USER** was exposed in the user's account description on the **APPLICATION**. This is an insecure method of password storage, allowing an unauthorized user to view credentials of **USER** on the network.

Business Impact

Having access to the **user's** cleartext password allows the attacker to impersonate the user and potentially access any PII stored under their account. Depending on the privileges of the compromised user, the attacker can potentially compromise other aspects of the application, laterally move across the system, and access the PII of other users.

Steps to Reproduce

Remediations

Team-XX recommends the following:

1. Enforce credential storage policies to ensure credentials are not stored in unencrypted, and easily accessible methods.
2. Audit all user descriptions and remove any sensitive information stored in the description.

3. Require the use of multi-factor authentication (MFA) by all users to minimize the risk of leaked credentials being abused by attackers.

References

[DigiCert - Creating Password Policy Best Practices](#)

[Palo Alto Networks - What is Multifactor Authentication \(MFA\) Implementation?](#)

H1: Privileged Public API Key

Matrix Calculation		CVSS Score	Risk
Impact	High	8.3	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application	
	Mitigations	M1054: Software Configuration	
Affected Scope			

Description

An API key for the **APPLICATION** is contained within the client-side source code, allowing users to view and use it. Attackers can leverage the API key to execute privileged read and write access on the backend server to view confidential server information.

Business Impact

Privileged API keys being available to the client allow an attacker to perform privileged reads and writes on the server, which can result in the leakage of PII or a compromise of the integrity of the system.

Steps to Reproduce

Depends on application

Remediations

Team-XX recommends the following:

1. Immediately reduce the permission level of the exposed API key and regenerate the affected API key as a precaution.
2. Any privileged leverage API calls should not display the key on the client side.

References

OpenAI - API Private Key Best Practices

Medium:

M1: Kerberoasting

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1558.003 - Steal or Forge Kerberos Tickets: Kerberoasting	
	Mitigations	M1041: Encrypt Sensitive Information M1027: Password Policies	
Affected Scope			

Description

An attacker with a valid, **low-privilege domain user account** can request encrypted tickets for **services** running on servers. Since the server does not have randomized or secure service account passwords, which is the default configuration, the attacker can take the stolen hashes offline and use brute-force techniques to crack the plaintext passwords.

Business Impact

This allows an adversary to compromise a service account, which can lead to a data breach, lateral movement across the network, and potential domain compromise if the account has high privileges. They can also cause severe operational disruption by modifying the service that the service account controls.

Steps to Reproduce

Step 1: Enumerate the Active Directory for accounts with Service Principal Names (SPNs) via Bloodhound.

Step 2: Request service tickets for the discovered SPN accounts using GetUserSPNs from Impacket.

Step 3: Export the tickets to a file

Step 4: Crack the ticket hashes offline using a tool like HashCat and wordlist like rockyou.txt to recover the password

Remediations

Team-XX recommends the following:

1. Enforce a strong password policy for all service accounts to prevent hash cracking after Kerberoasting.
2. Disallow user accounts from having a Service Principal Name (SPN) and implement the principle of least privilege to limit service account permissions.
3. Implement Windows Defender or another Antivirus solution to detect and prevent common AD attacks.

References

[Microsoft Security - Microsoft's guidance to help mitigate Kerberoasting](#)

M1: Plaintext Passwords in Database

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.8	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1555: Credentials from Password Stores T1552: Unsecured Credentials T1005: Data from Local System	
	Mitigations	M1041: Encrypt Sensitive Information	
Affected Scope			

Description

Passwords in the database are stored in plaintext, allowing attackers that gain access to the database the ability to easily discover and utilize user passwords.

Business Impact

An attacker can compromise any user account in the database without the need to crack the hashes of the passwords before use. This can lead to the exposure of sensitive information and potential operational disruptions depending on the privileges of the compromised user.

Steps to Reproduce

Step 1: Login to the database

Code block here `mysql -u admin -p`

Step 2: Access the database

Code block here `use wp-database`

Step 3: View the stored passwords

Code block here `SELECT Passwords FROM User_Data;`

Remediations

Team-XX recommends the following:

1. Stored passwords should be encrypted using a strong encryption/hash method that is hard to brute force.
2. Hashes should be salted and peppered to prevent the attacker from being able to crack hashes offline through brute forcing.

Resources

[OWASP - Password Storage Cheat Sheet](#)

[Netsec - Password Salting and Peppering](#)

M1: Public Access to WP-Cron.php

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.8	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application	
	Mitigations	M1054: Software Configuration M1042: Disable or Remove Feature or Program	
Affected Scope			

Description

An attacker can exploit the WP-Cron.php script, which is used to schedule and run background tasks on WordPress, by repeatedly hammering it with requests in an attempt to cause a Denial of Service (DOS) attack. Successful exploitation impacts the availability of the WordPress website for all users.

Business Impact

This will cause server performance to be impacted and could cause the website to become unavailable due to a high number of resources being used by the attacker, impacting the availability of the WordPress server.

Steps to Reproduce

As this penetration test was run against the live production environment, **Team-XX** did NOT run any exploits that would impact the availability of the system, preventing other users from being able to perform regular customer and employee workflow. However, we know the vulnerability is present because:

Step 1. Visit /wp-cron.php

Step 2. Observe that the server does not issue a 404 status, or a similar response

Remediations

Team-XX recommends the following:

1. Block any external IP address from accessing WP-Cron.php by explicitly denying all incoming requests in the .htaccess file.
2. If the WP-Cron service is not in use or required, it is highly recommended to disable the feature to reduce attack surface.

Resources

[In-Motion Hosting: WP-Cron Security Management](#)

M1: Server-Side Request Forgery

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.3	Medium
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:L/SI:N/SA:L	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application	
	Mitigations	M1035: Limit Access to Resource Over Network M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

Server-Side Request Forgery (SSRF) is a web vulnerability that allows an attacker to have a server-side application send requests to an unintended location. An attacker can fetch content from an external URL and trick the application into making requests for internal services or resources that are not normally accessible from the outside.

Business Impact

An attacker successfully exploiting SSRF can map the internal network and possibly access sensitive data from internal services. They can steal sensitive information and cause financial and reputational damage to the APT organization.

Steps to Reproduce

Step 1: View the application function **X** on **X** and see that it takes a user-supplied URL as input.

Step 2: Replace the legitimate external URL with a URL pointing to a service controlled by yourself and verify that the server makes an outbound request.

Step 3: Attempt to access internal IP addresses like **X** and view internal services.

Remediations

Team-XX recommends the following:

1. Validate user input by implementing a whitelist of allowed domains, IP addresses, and protocols that the application is permitted to request. Validate all user-supplied URLs against this list.
2. If a whitelist is not possible to implement, implement a blacklist of disallowed, malicious domains, IP address, and protocols.

References

[OWASP - Server Side Request Forgery \(SSRF\)](#)

[Portswigger - What is SSRF?](#)

M1: Kiosk Breakout

Matrix Calculation		CVSS Score	Risk
Impact	Medium	5.9	Medium
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1611: Escape to Host	
	Mitigations	M1026: Privileged Account Management M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

An attacker is able to breakout of the restricted environment and access the underlying computer environment. After breaking out of the restricted environment, the user can access sensitive files and perform arbitrary PowerShell commands as a high-privilege user.

Business Impact

Successfully breaking out of the kiosk allows an attacker to access potentially private documents on the machine and allow them to escalate to higher privilege users and gain more control over the network.

Steps to Reproduce

Step 1:

Remediations

Team-XX recommends the following:

1. Run the kiosk as a restricted user with no privileged permissions.
2. Disallow the ability to open arbitrary files or access PowerShell and Command Prompt, to prevent further abuse if a user performs a successful kiosk breakout.

References

[NVISO Labs: Breaking out of Windows Kiosks](#)

M1: Weak Password Policies

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1110.003: Password Spraying	
	Mitigations	M1027: Password Policies M1032: Multi-Factor Authentication	
Affected Scope			

Description

The affected host's password policy was found to have weak requirements that allow for passwords that are easily cracked using brute force attacks.

Business Impact

This vulnerability can lead to operational disruptions and data leakage as an attacker that discovers a user's credentials can impersonate them and modify resources under their control.

Steps to Reproduce

Step 1: Run a brute force attack systematically guessing passwords.

Remediations

Team-XX recommends the following:

1. Implement and enforce a strong password policy for all accounts to ensure attackers are unable easily brute force passwords. As a baseline the following minimum password policy is recommended:
 - a. Minimum of 12 characters
 - b. At least one uppercase character, one lowercase character, one digit character, and one special symbol.

- c. Unique passwords for each user and service to prevent password reuse
- 2. Implement a lockout policy to block attackers after repeated failed login attempts, preventing them from brute forcing credentials.
- 3. Implement multi-factor authentication to prevent access even with leaked or disclosed passwords.

References

[DigiCert - Creating Password Policy Best Practices](#)

[Linode - Fail2Ban for SSH Brute-force Protection](#)

[Palo Alto Networks - Multi Factor Authentication](#)

M1: Password Reuse

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1110.003: Password Spraying	
	Mitigations	M1036: Account Use Policies M1032: Multi-Factor Authentication M1027: Password Policies	
Affected Scope			

Description

Multiple accounts on the network were found to be using the same password.

Business Impact

This vulnerability can lead to operational disruptions and data leakage as an attacker that knows the credentials for a user can gain access to other users in the network. This allows the attacker to impersonate them and access resources under their control.

Steps to Reproduce

Step 1: Attempt to use the password for user X for user Y

Remediations

Team-XX recommends the following:

1. Implement a strong password policy that prohibits reused passwords across multiple accounts or services.
2. Implement multi-factor authentication to prevent access even with reused passwords.
3. Utilize a password manager to encourage employees to avoid reusing passwords.

4. Train all users on the risk of password reuse.

References

[DigiCert - Creating Password Policy Best Practices](#)

[Palo Alto Networks - Multi Factor Authentication](#)

M1: Cookie Manipulation

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1606.001: Forge Web Credentials - Web Cookies	
	Mitigations	M1041: Encrypt Sensitive Information	
Affected Scope			

Description

The web application stores user authorization roles in a client-side cookie and uses this value to determine access levels. An attacker can modify the cookie value from guest to administrator, and the server accepts the modified value without verification, granting administrative access to the web server.

Business Impact

This vulnerability can allow for a low-privileged or unauthorized user to gain administrative access to the webserver. This allows them to view sensitive information, including other user data, alter sensitive information, or take down or change the webserver.

Steps to Reproduce

- Step 1: Authenticate as a guest user
- Step 2: Observe the cookies set in browser dev tools
- Step 3: Alter 'Guest' to 'Admin'
- Step 4: Reload the page and observe admin panel is now visible

Remediations

Team-XX recommends the following:

1. Do not store role or permission data as mutable, plaintext cookies on the client-side. Store only a server-generated session identifier and maintain authoritative user/role permission on the server-side.
2. Remove any logic that grants admin access purely based on unsigned cookie values.
3. Use signed tokens (JWT) and always validate the signature and claims server-side
4. Set the cookie to have the *Secure* flag

References

[MITRE CWE - Reliance on Cookies without Validation and Integrity Checking](#)
[OWASP - Testing for Cookie Attributes](#)

M1: Windows Defender Disabled

Matrix Calculation		CVSS Score	Risk
Impact	Medium	N/A	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1562.001:Impair Defenses - Disable or Modify Tools	
	Mitigations	M1047: Audit M1050: Exploit Protection	
Affected Scope			

Description

The **machine** has Real-Time Protection and Windows Defender disabled. This removes the primary defense layer of the machine, leaving the system exposed to common attacks.

Business Impact

An attacker can successfully compromise the machine without interference, alerting, or prevention of an active Antivirus, which makes the machine an easy target for malware infection. A compromise can result in the theft of sensitive data and allow attackers to launch further attacks against other systems within the internal network.

Steps to Reproduce

Step 1: Log into the affected Windows machine with a user.

Step 2: Open PowerShell and run 'Get-MPCComputerStatus' and observe that the RealTimeProtectionEnabled option is set to 'false'.

Remediations

Team-XX recommends the following:

1. Enable Windows Defender and ensure that 'Real-time protection', 'Cloud-delivered protection', and 'Tamper protection' are enabled on the host.

2. Set the correct Windows Defender settings via Group Policy Objects (GPO) to enforce it across a domain environment, preventing users from disabling it and ensuring a consistent security posture.

References

[Microsoft - Microsoft Defender Antivirus in the Windows Security App](#)

M1: Insecure Direct Object Reference (IDOR)

Matrix Calculation		CVSS Score	Risk
Impact	Medium	5.3	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:L/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1567: Exfiltration Over Web Service T1213: Data from Information Repositories	
	Mitigations	M0801: Access Management M0800: Authorization Enforcement	
Affected Scope			

Description

The machine hosts a webserver that exposes object identifiers (ID) in URLs or API parameters and relies on those client-supplied IDs to return user data. No authorization checks are done, meaning that any authenticated user can modify or retrieve the identifier, allowing users to act on behalf of all other users.

Business Impact

This can lead to the leakage of sensitive data, which can hurt the public reputation of All Ports Tours and lead to fines. Attackers can also view and modify sensitive data of all other users, resulting in significant confidentiality and integrity impact.

Steps to Reproduce

Step 1: Log into the website

Step 2: Modify the ID number in the HTTP GET request

Remediations

Team-XX recommends the following:

1. Implement strict access control checks to restrict users to only access permitted files and objects. It is recommended to not rely on obscurity or client-side checks.
2. Use random non-guessable identifiers to prevent attackers from guessing the ids of other resources
3. Utilize short-lived, signed, or tokenized URLs when sharing sensitive files or resources instead of static IDs.

References

[CISA - Preventing Web Application Access Control Abuse](#)

[OWASP - IDOR Prevention](#)

M1: File Disclosure

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1213: Data from Information Repositories T1005: Data from Local System	
	Mitigations	M1057: Data Loss Prevention M1022: Restrict File and Directory Permissions	
Affected Scope			

Description

An unauthenticated user can read arbitrary files from the machine's file system without authentication through the API endpoint or URL parameter.

Business Impact

Attackers can exploit this vulnerability to access sensitive information including user credentials, application secrets, system configuration files, and backend code as an unauthenticated user.

Steps to Reproduce

Step 1: Log into the website and view the **API endpoint or URL parameter** that loads the file **X** from the server.

Step 2: Manipulate the parameter to read a sensitive file from the operating system using path traversal characters (../) and read /etc/passwd.

Step 3: Send the request to the modified endpoint and view that the contents of /etc/passwd file are returned.

Remediations

Team-XX recommends the following:

1. Require user authentication on any endpoint that reads internal files
2. Deny absolute paths and any path containing traversal sequences (..) if the API should not be able to read sensitive internal files.
3. Sandbox the application and restrict its file access to known safe directories. This prevents traversal to sensitive system files and directories.

References

[OWASP - Path Traversal](#)

[PortSwigger - What is directory traversal?](#)

M1: Default Credentials in Web Applications

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1078: Valid Accounts T1082: Default Credentials	
	Mitigations	M0801: Access Management M0927: Password Policies	
Affected Scope			

Description

An attacker can gain authorized access to the HTTP **service** by logging in with well-known and publicly available default credentials. As these credentials are publicly accessible, they are easily guessable by an attacker.

Business Impact

An attacker can leverage these default credentials to gain unauthorized access to the **HTTP** service, giving them an initial foothold into the network. This allows them to potentially obtain sensitive information or administrative functionality.

Steps to Reproduce

Step 1: Go to **WEBSITE** on a web browser

Step 2: Login with default credentials found here:

Remediations

Team-XX recommends the following:

1. Immediately change default credentials for all applications on the network to strong, unique passwords in accordance with a set password policy.

2. Always identify and change default credentials before putting any service or device on the network.

References

[Palo Alto Networks - Multi Factor Authentication](#)

[DigiCert - Creating Password Policy Best Practices](#)

M1: Hard-Coded Credentials in Application

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T0891: Hardcoded Credentials T1078: Valid Accounts	
	Mitigations	M0801: Access Management	
Affected Scope			

Description

The **HTTP** service on **MACHINE1** utilizes hard-coded credentials found in the application's **JavaScript** client-side code. This exposes valid credentials to anyone with access to the website, allowing attackers to authenticate as an internal user.

Business Impact

An attacker can leverage these client-side credentials to gain a foothold into the internal network. This can lead to unauthorized access to internal APIs or systems, exposing sensitive data, and enabling further compromise.

Steps to Reproduce

- Step 1: Go to **WEBSITE** on a web browser
- Step 2: Press CTRL + U to view the page source code
- Step 3: View hard-coded credentials

Remediations

Team-XX recommends the following:

1. Remove all hard-coded credentials from client-side code. Never include test or debug credentials in files deployed to production, instead use

environment variables or secure credential stores to manage secrets safely.

2. Use secure secret management and coding practices by storing all sensitive credentials in environment variables, configuration files outside Webroot, or in centralized secret management systems.
3. Immediately rotate all exposed credentials immediately and audit related systems for unauthorized access.

References

[OWASP - Vulnerabilities: Use of Hard-Coded Credentials](#)

[MITRE CWE-259: Use of Hard-coded Password](#)

M1: AS-REP Roasting

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1558.004 - Steal or Forge Kerberos Tickets: AS-REP Roasting	
	Mitigations	M1047: Audit M1027: Password Policies	
Affected Scope			

Description

An attacker on the network can request authentication data for a user that does not have Kerberos pre-authentication enabled and receive an encrypted ticket from the Domain Controller. This ticket is encrypted with the user's password, and an attacker can then take them offline and use brute-force techniques to crack the password.

Business Impact

This vulnerability can lead to user account compromise without the attacker needing any prior access. Depending on the privileges of the compromised account, it can result in a breach of sensitive data, unauthorized access to sensitive systems, and operational disruption by modifying some services running on the machine.

Steps to Reproduce

Step 1: Enumerate the Active Directory for users with the "Do Not Require Kerberos Preauthentication" feature enabled.

Step 2: Request an AS-REP ticket for the discovered user accounts from the Domain Controller.

Step 3: Export the received hash to a file

Step 4: Crack the hash offline using a tool like hashcat and wordlist like rockyou.txt to recover the password.

Remediations

Team-XX recommends the following:

1. Enable Kerberos pre-authentication for all user accounts in Active Directory. This is the default setting and should not be disabled.
2. Enforce a strong password policy for all service accounts to prevent hash cracking after AS-REP Roasting.

References

[TCM Security - Pre-Authentication in AD Environments](#)

[Microsoft - AS-REP Roasting Detection and Prevention](#)

M1: Local File Inclusion

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1005: Data from Local System T1083: File and Directory Discovery	
	Mitigations	M1057: Data Loss Prevention M1022: Restrict File and Directory Permissions M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

The **page** parameter under **/documents** is vulnerable to Local File Inclusion, giving an attacker the ability to read any file on the backend server that the **www-data** user has permission to access.

Business Impact

Attackers can abuse the vulnerability to access sensitive customer and business data, configuration files, databases, and proprietary code stored on the backend system. Attackers will gain more information about the system which they can use to find further vulnerabilities in the system.

Steps to Reproduce

Step 1: Go to **WEBSITE** on a web browser

Step 2: Under the page parameter enter path to a local file that should not be accessible through the website, such as `/etc/passwd`

Step 3: Examine the file contents displayed on the web page

Remediations

Team-XX recommends the following:

1. Avoid passing filenames in user input, including direct user input as well as other data sources that can be manipulated by the attacker, such as cookies.
2. If file access through user input is required, create a whitelist of safe file paths. In cases where a whitelist cannot be used (such as arbitrary filenames), store filenames in a database and use table row identifiers in user input.

Reference

[OWASP - Testing for Local File Inclusion](#)

M1: Anonymous LDAP Bind

Matrix Calculation		CVSS Score	Risk
Impact	Medium	6.9	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:L/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1482: Domain Trust Discovery T1087.002: Account Discovery - Domain Account	
	Mitigations	M1047: Audit M1030: Network Segmentation	
Affected Scope			

Description

The LDAP (Lightweight Directory Access Protocol) service allows anonymous binding which permits unauthenticated users to connect to Active Directory and query sensitive information. LDAP stores user account details, group memberships, and computer information for the domain.

Business Impact

Attackers can perform reconnaissance without any credentials, gathering information about the internal network, including usernames, group details, and network services. This can be used for further attacks such as password spraying, phishing, and targeted exploitation of user accounts.

Steps to Reproduce

Step 1: Use ldapsearch to connect to the LDAP server and bind to the server without providing a username or password

Step 2: Perform a search query **X** to search for common objects and view the returned query.

Remediations

Team-XX recommends the following:

1. Disable Anonymous LDAP Binds and configure the Active Directory server to reject anonymous bind requests. Do this by modifying the dSHeuristics attribute.

2. Restrict access to the LDAP service to trusted hosts and network segments.

References

[Microsoft Security Advisory ADV190023](#)
[How to check for anonymous LDAP binding](#)

M1: Stored XSS (no cookies)

Matrix Calculation		CVSS Score	Risk
Impact	Medium	5.1	Medium
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:L/UI:P/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1189: Drive-by Compromise	
	Mitigations	M0818: Validate Program Inputs M1021: Restrict Web-Based Content	
Affected Scope			

Description

Unsanitized user input is stored on the server and is sent to the client as HTML when viewed, allowing an attacker to run arbitrary JavaScript code on the client. This allows an attacker to upload a malicious script as user input, which when rendered by **another user or**, can alter the display of the website.

Business Impact

This allows a malicious actor to manipulate other client sessions to render JavaScript code that can be used to render attacker-controlled HTML, and alter the functionality of the website for other users, which can be used to display a fake phishing login leading to user account compromise.

Steps to Reproduce

Step 1: Create a post with the following payload `<script>alert(1)</script>`

Step 2: View the post

Remediations

Team-XX recommends the following:

1. Validate and normalize all user input on the server with a whitelist if applicable. Always encode output and never store raw HTML or JavaScript from untrusted user input without sanitization.

2. Implement a Web Application Firewall to block malicious JavaScript payloads.
3. Utilize a strict Content Security Policy to restrict JavaScript sources.
4. Mark session cookie configurations such as *HttpOnly*, *Secure*, and *SameSite=Strict* to protect cookies from exfiltration.

References

[Mozilla - Secure Cookie Configurations](#)

[Portswigger - Cross Site Scripting Prevention](#)

M1: LDAP Signing and Channel Binding Not Enabled

Matrix Calculation		CVSS Score	Risk
Impact	Medium	5.1	Medium
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:A/AC:L/AT:N/PR:L/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1557: Adversary in the Middle T1040: Network Sniffing	
	Mitigations	M1041: Encrypt Sensitive Information M0931: Network Intrusion Prevention	
Affected Scope			

Description

LDAP Signing and Channel Binding is not enabled on the system. As a result, LDAP sessions lack integrity and verification, allowing for attackers to perform a man-in-the-middle attack to intercept and manipulate data. Additionally, a relay attack can be performed to intercept network authentication hashes, which can lead to account compromise.

Business Impact

This vulnerability can lead to the compromise of network accounts through a relay attack. Attackers can perform a man-in-the-middle attack which will result in compromise of confidentiality and integrity of communication over the network.

Steps to Reproduce

1. Use the `ldap_checker` module from `netexec` to check LDAP and Channel Binding settings, given valid LDAP credentials discovered previously.

Remediations

Team-XX recommends the following:

1. Enable LDAP server signing by setting the Domain Controller LDAP server signing requirements policy to *Require signing*

2. Enable LDAP Channel Binding Tokens in Group Policy (GPO) on the Domain Controller

Reference

[Microsoft - LDAP Channel Binding and LDAP Signing Requirements](#)

[Microsoft - How to Enable LDAP Signing](#)

M1: SMTP Open Relay

Matrix Calculation		CVSS Score	Risk
Impact	Medium	5.3	Medium
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1534: Internal Spearphishing T1598: Phishing for Information	
	Mitigations	M1054: Software Configuration M0801: Access Management	
Affected Scope			

Description

The SMTP server allows for unauthorized email transmission, allowing attackers to send targeted spam or malicious phishing emails to ATP employees and customers from the SMTP server.

Business Impact

This vulnerability compromises email system integrity and allows the attacker to potentially phish for sensitive information or credentials through a targeted phishing campaign. An attacker can send out massive amounts of spam or malicious phishing emails, getting the IP to be blacklisted due to high amounts of malicious or spam traffic seen from the server.

Steps to Reproduce

1. Use swaks and run `swaks -f user@domain -t user@domain -d email.eml -s 10.0.0.0:25`

Remediations

Team-XX recommends the following:

1. Configure the SMTP server to disable open relay functionality, including setting up proper authentication for email senders and restricting the list of IP addresses allowed to relay emails.
2. Implement additional email security measures such as SPF (Sender Policy Framework), DKIM (Domain Keys Identified Mail), and DMARC (Domain-based Message Authentication, Reporting, and Conformance) to prevent email spoofing and ensure email authenticity.

Reference

[DuoCircle - SMTP Open Relay Vulnerability](#)

[Higherlogic - SPF, DKIM, DMARC Email Authentication](#)

M1: Missing HTTP security headers

Matrix Calculation		CVSS Score	Risk
Impact	Medium	N/A	Medium
Likelihood	Low		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1189: Drive-by Compromise T1204.001: User Execution - Malicious Link	
	Mitigations	M1021: Restrict Web-Based Content M1050: Exploit Protection	
Affected Scope			

Description

The affected web servers lack the following recommended security headers:

1. X-Frame-Options
2. X-Content-Type-Options
3. Strict-Transport-Security
4. Referrer-Policy
5. Permissions-Policy
6. Content-Security-Policy

These security headers are crucial for hardening web applications from common client-side attacks.

Business Impact

The lack of security headers increases the attack surfaces for the affected hosts, allowing threat actors to exploit client-side vulnerabilities in web applications. These potential attacks can lead to hijacking user accounts by stealing their cookies or credentials. If a privileged account is compromised, sensitive customer and business data can be leaked.

Steps to Reproduce

Step 1: Run Nikto on the affected hosts and observe their security headers.

Remediations

Team-XX recommends the following:

1. Implement recommended security headers for all web applications.
Provided below are the baseline recommendations, and they should be modified as needed to maintain functionality of the websites:
 - a. X-Frame-Options: SAMEORIGIN
 - b. X-Content-Type-Options: nosniff
 - c. Strict-Transport-Security: max-age=31536000; includeSubDomains
 - d. Referrer-Policy: strict-origin-when-cross-origin
 - e. Permissions-Policy: accelerometer=(), camera=(), geolocation=(), gyroscope=(), magnetometer=(), microphone=(), payment=(), usb=()
 - f. Content-Security-Policy: default-src 'self'; object-src 'none'; frame-ancestors 'none'; base-uri 'self'; form-action 'self';
2. Use the [securityheaders](#) scanning tool to verify their implementation.

References

[Mozilla - HTTP Headers](#)

M1: Low LAN Manager Authentication Level

Matrix Calculation		CVSS Score	Risk
Impact	Medium	N/A	Medium
Likelihood	Medium		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1557.001: Adversary-in-the-Middle - LLMNR/NBT-NS Poisoning and SMB Relay	
	Mitigations	M1042: Disable or Remove Feature or Program M1037: Filter Network Traffic	
Affected Scope			

Description

The **domain** is configured with a low LAN Manager authentication level, which allows for the use of weak legacy authentication protocols such as NTLMv1 and LM hashing. These outdated protocols are vulnerable to various attacks including pass-the-hash, relay attacks, and offline cracking due to their weak cryptographic implementations compared to modern hashing.

Business Impact

This vulnerability can lead to both **low and high privileged** accounts' NTLM hashes being intercepted and cracked through man-in-the-middle attacks. Additionally, unauthorized access can be gained to the **system** through SMB relay attacks, allowing attackers to gain control of higher privileged user accounts on the network.

Steps to Reproduce

- Step 1: Identify the current LAN Manager authentication level
HKLM\SYSTEM\CurrentControlSet\Control\Lsa\LMCompatibilityLevel
- Step 2: Run Responder to capture authentication attempts
Python3 responder.py -l eth0
- Step 3: Capture the NTLMv1 or LM hashes from authentication traffic

Step 4: Crack the captured hash using hashcat or associated tool to recover plaintext password

Remediations

Team-XX recommends the following:

1. Set the security policy "Network security: LAN Manager authentication level" to "Send NTLMv2 response only. Refuse LM & NTLM" (level 5) on all domain controllers and member systems via Group Policy.
2. Disable LLMNR if applicable, to prevent LLMNR Poisoning

References

[Microsoft - Network security: LAN Manager authentication level](#)

M1: Exposed DB Data from API

Matrix Calculation		CVSS Score	Risk
Impact	Medium		

Likelihood	High	6.9	Medium
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1567: Exfiltration Over Web Service T1213: Data from Information Repositories	
	Mitigations	M1041: Encrypt Sensitive Information M1035: Limit Access to Resource Over Network	
Affected Scope			

Description

The exposed **API endpoint** allowed unauthorized users to query database information directly without proper authentication.

Business Impact

An attacker can craft API requests to retrieve sensitive information directly from the database, including personally identifiable information (PII), credentials, internal system data, or business-critical information.

Steps to Reproduce

Step 1: Identify **API vulnerable endpoint** through web scanning or Burp Suite
Step 2: Send unauthenticated GET or POST requests to the API endpoint
Step 3: Observe the API responses for sensitive database fields such as email, password, or id

Remediations

Team-XX recommends the following:

1. Implement authentication and authorization on all API endpoints that deal with sensitive information.
2. Implement encryption at rest and during transfer of all sensitive data.
3. Enable comprehensive API logging and monitoring.

References

[OWASP - API Security Top 10](#)

Low Vulnerability

L1: Reflective XSS

Matrix Calculation		CVSS Score	Risk
Impact	Medium	4.8	Low
Likelihood	Low		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:L/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1189: Drive-by Compromise	
	Mitigations	M0818: Validate Program Inputs M1021: Restrict Web-Based Content	
Affected Scope			

Description

An attacker can craft a malicious URL that contains a JavaScript payload that will be reflected in the user's browser when they click the URL.

Business Impact

Attackers can abuse this vulnerability to execute arbitrary JavaScript code in the victim's browser by distributing malicious links through phishing attempts, social engineering, and compromised websites. This can be abused to hijack session cookies or send malicious alerts and messages to other users.

Steps to Reproduce

Step 1: Go to **WEBSITE** on a web browser

Step 2: Inject a malicious XSS payload into a URL parameter (e.g., [https://WEBSITE/search?q=<script>alert\('XSS'\)</script>](https://WEBSITE/search?q=<script>alert('XSS')</script>))

Step 3: Send the crafted URL to a victim

Step 4: When the victim clicks the malicious URL the script will be executed

Remediations

Team-XX recommends the following:

1. Properly sanitize all user input before storing or passing any data to users. Sanitization functions are present in all programming languages that will encapsulate and prevent the execution of any malicious user input.
2. Utilize a web application firewall to block dangerous requests and common injection patterns.
3. Utilize a strict Content Security Policy to restrict JavaScript sources.
4. Mark session cookie configurations as *HttpOnly*, *Secure*, and *SameSite=Strict* to protect cookies from exfiltration.

Reference

[Mozilla - Secure Cookie Configurations](#)

[OWASP - XSS Attacks](#)

[Portswigger - Cross Site Scripting Prevention](#)

L1: Lack of anti-CSRF Tokens

Matrix Calculation		CVSS Score	Risk
Impact	Medium	5.1	Low
Likelihood	Low		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1078: Valid Accounts T1190: Exploit Public Facing Application	
	Mitigations	M1054: Software Configuration	
Affected Scope			

Description

The affected web applications do not implement CSRF protection. Without anti-CSRF tokens, an attacker can trick an authenticated victim to make unintended requests to the server. These requests can maliciously modify data, such as user passwords, in the server.

Business Impact

If a privileged user is tricked by a threat actor into sending requests to the server to modify critical data, the data integrity of APT's network will be compromised. Attackers can leverage this configuration to phish for other ATP clients and manipulate data to hijack other user accounts.

Steps to Reproduce

- Step 1: Go to **WEBSITE** on a web browser.
- Step 2: Intercept any post request that modifies data.
- Step 3: Observe that it does not use any CSRF token.

Remediations

Team-XX recommends the following:

1. Implement anti-CSRF tokens, using unique and random tokens for every request.

2. Validate all anti-CSRF tokens on the server side before processing any request.

Reference

[OWASP - Cross Site Request Forgery](#)

L1: SMTP Unenforced DKIM and DMARC

Matrix Calculation		CVSS Score	Risk
Impact	Medium	2.3	Low
Likelihood	Low		
CVSSv4.0 Attack Vector		AV:N/AC:H/AT:N/PR:L/UI:N/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1534: Internal Spearphishing T1598: Phishing for Information	
	Mitigations	M1054: Software Configuration	
Affected Scope			

Description

The SMTP server is missing a DMARC and DKIM record. Unenforced DMARC allows an attacker to spoof the domain in phishing attacks by allowing unauthorized use of the domain in the Friendly-From address of email messages. Unenforced DKIM means that verification of senders is not performed on the SMTP server, enabling users to more easily perform phishing campaigns on ATP employees.

Business Impact

Attackers can abuse this misconfiguration to perform domain spoofing in targeted phishing campaigns on ATP employees. These emails will not be verified as coming from internal ATP employees but will appear to be coming from the ATP domain. This will make phishing attempts much harder to detect and will likely result in increased employee interaction with malicious, phishing emails.

Steps to Reproduce

Step 1: `swaks -ehlo user@domain -from name@domain -to user@domain -server smtp.server.local --h-From "Name" <name@domain> --attach-type text/html --attach-body @Mail-template.html`

Remediations

Team-XX recommends the following:

1. Enforce DMARC by adding a record to the domain and specifying the enforcement policy to quarantine or reject emails containing a mismatch between sender and from, which is likely to be a domain spoofing attempt.
2. Enforce DKIM which will verify domain identities when sending emails.
3. Implement email quarantining and filtering to block malicious emails and phishing attempts from being delivered to employee inboxes.

Reference

[RackSpace - Create a DMARC Policy](#)

[RackSpace - Enable DKIM](#)

[Higherlogic - SPF, DKIM, DMARC Email Authentication](#)

Informational:

I1: Excessively Privileged Application

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1611: Escape to host T1098: Account Manipulation	
	Mitigations	M0926: Privileged Account Management	
Affected Scope			

Description

The **API** service is running as a privileged user, significantly increasing the effectiveness of chain exploits. An attacker running commands will end up running those commands as privileged user, giving them increased access and permissions to backend files and services.

Business Impact

If the **SERVICE** service is exploited, an attacker will immediately have privileged access on the backend system. This misconfiguration significantly increases the criticality of any other vulnerability, as it is run by an excessively privileged user.

Steps to Reproduce

Step 1: Check what user is running the program by running “ps -p XXX”

Step 2: Check the users' permissions by running “id user”

Remediations

Team-XX recommends the following:

1. Implement the Principle of Least Privilege so that non-privileged system accounts have only the minimum permissions required to function.
2. Creating service accounts with limited access, following the Principle of Least Privilege.
3. Regularly audit user and system account permissions to ensure no privilege creep occurs over time.

References

[CrowdStrike - Principle of Least Privilege](#)

I1: Anonymous FTP Login

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1105: Ingress Tool Transfer T1048: Exfiltration Over Alternative Protocol	
	Mitigations	M1022: Restrict File and Directory Permissions M1035: Limit Access to Resource Over Network	
Affected Scope			

Description

Anonymous FTP login is permitted on the internal FTP server. This allows any unauthenticated user to view any internal files that are not restricted to specific users on the FTP server. Attackers can also bring exploit tools into the network by uploading them to the FTP share, allowing for privilege escalation and pivoting.

Business Impact

If the FTP server is utilized to serve sensitive files and data, attackers are easily able to anonymously log in and view the data on the FTP server. Attackers can also abuse the FTP server to get exploitation tools into the internal network and exfiltrate sensitive data out of the internal environment, which is harder to detect and prevent than other infiltration/exfiltration methods.

Steps to Reproduce

Step 1: Log into FTP server with anonymous username and any password

Step 2: Use the ls command to view data and files stored on the FTP server

Step 3: Use put to transfer exploitation tools and scripts into the internal network

Remediation Strategies

Team-XX recommends the following:

1. Disable anonymous FTP login if there is no explicit reason to require it.
2. If anonymous FTP is required, it is recommended that anonymous users do not have access to any sensitive information and files that should not be publicly accessible. It is also recommended to disallow anonymous users from being able to upload any files to the FTP server.

References

[IBM - FTP Security](#)

I1: SMB Share Guest Access

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1021.002: Remote Services: SMB/Windows Admin Shares T1105: Ingress Tool Transfer	
	Mitigations	M1022: Restrict File and Directory Permissions M1035: Limit Access to Resource Over Network	
Affected Scope			

Description

Guest SMB Access is permitted on the internal SMB server. This allows any unauthenticated user on the network to connect and view any internal files without needing to provide valid credentials.

Business Impact

If the internal SMB server is utilized to serve sensitive files and data, attackers are easily able to anonymously log in and view the data on the SMB server. Attackers can also abuse the internal SMB server to get exploitation tools into the internal network and exfiltrate sensitive data out of the internal environment, which is harder to detect and prevent than other infiltration/exfiltration methods.

Steps to Reproduce

Step 1: Log into SMB server with no username and no password

Step 2: Use the ls command to view data and files stored on the SMB server

Step 3: Use put to transfer exploitation tools and scripts into the internal network

Remediation Strategies

Team-XX recommends the following:

1. Disable Guest SMB authentication via the Group Policy to enable enforcement for the entire domain. Navigate to 'Computer Configuration\Administrative Templates\Network\Lanman Workstation' and set "Enable insecure guest logons" to Disabled.
2. Ensure that all shares are configured with explicit permissions that allow access on the basis of the principle of least privilege, allowing only authorized users and groups to connect.

References

[Microsoft - SMB security hardening](#)

[Absolute - Disable Guest Logons](#)

I1: Exposed API Documentation

M0800 Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	TA0043: Reconnaissance	
	Mitigations	M0801: Access Management M0800: Authorization Enforcement	
Affected Scope			

Description

API documentation is publicly exposed, allowing attackers to view what API calls can be made when going to the HTTP page. Attackers can abuse this to be able to learn what API calls are possible and how to execute API calls, such as being able to read internal files on the host server.

Business Impact

API documentation being publicly exposed allows attackers to view what API calls can be made and potentially retrieve internal documents and files. These API calls can then be used to exfiltrate data and gain sensitive information, such as personal information or network credentials.

Steps to Reproduce

Step 1: Go to the HTTP webpage

Step 2: Go to the following **PAGE** based on the API documentation

Remediation Strategies

Team-XX recommends the following:

1. Remove or relocate API documentation if it is not required to be public knowledge for all APT users.

2. Implement authentication on API documentation endpoints to ensure that only authorized users can access documentation.

References

[Speakeasy - Exposing your API publicly](#)

I1: Outdated TLS Version

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1562-010: Downgrade Attack	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

The installed TLS version used in **APPLICATION** has an outdated version; the latest TLS version is 1.3, while the application uses TLS **VERSION**. An attacker can potentially exploit this outdated version, possibly in combination with other exploits, to gain access to information or systems that they should not be able to.

Business Impact

An attacker could potentially exploit an outdated TLS version to carry out a downgrade attack or other similar exploits, which could allow decryption of traffic. Traffic decryption allows for reading information such as passwords in plaintext, which can cause severe security issues.

Steps to Reproduce

Step 1: Use sslscan to check the TLS version. sslscan IP

Remediation Strategies

Team-XX recommends the following:

1. Modify configurations to support the newest TLS version available (TLSv1.3)

References

[Microsoft - Solving the TLS1 problem](#)

Trace Security - Disabling deprecated TLS protocols

I1: User Enumeration Through Failed Login

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	Medium		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1087: Account Discovery	
	Mitigations	M1054: Software Configuration	
Affected Scope			

Description

Upon credentials being entered, the **sign-in/register** page issues a different response based on whether or not an account with the provided name already exists. This allows an attacker to determine if a user exists, making it possible to enumerate users on the system.

Business Impact

This is not a significant issue in and of itself but exploiting this functionality to enumerate users (likely with a word list) is useful in chain attack. For example, an attacker could determine the exact name of an admin account and then try to brute-force the password of that account.

Steps to Reproduce

Step 1: Go to **PAGE**

Step 2: Enter a random username with any arbitrary password

Step 3: Enter an existing username with any arbitrary password

Step 4: Observe the response being different

Remediation

Team-XX recommends the following:

1. Issue the same error of invalid name or password regardless of if a valid username was inputted into the login request.

2. Implement rate limited login requests to prevent a malicious actor from attempting a large amount of login requests in a short time frame, to avoid user enumeration.

References

[OWASP - Account Enumeration](#)

I1: Deprecated Windows Server Version

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	Medium		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1595: Active Scanning	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

The identified hosts are running Windows Server 2016, an operating system that will no longer be supported with regular security updates by Microsoft after 2027. This means that future vulnerabilities won't be patched and can be exploited by attackers.

Business Impact

In the future, as new vulnerabilities are discovered, this can be an issue to the company as much of the core infrastructure uses Windows Server 2016. If these machines are compromised, the operational integrity of the entire network will be in danger, possibly leading to loss of life.

Steps to Reproduce

Step 1: Use enum4linux-ng to scan the host

enum4linux-ng-A hostname

Step 2: Observe the operating system version to be Windows Server 2016

Remediation Strategies

Team-XX recommends the following:

1. Update all servers running Windows Server 2016 to the latest version of Windows Server 2022

References

[Microsoft - Windows Server 2016 Lifecycle](#)

I1: Deprecated Windows 10

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	Medium		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1595: Active Scanning	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

The identified hosts are running Windows 10 which has been deprecated by Microsoft on October 14, 2025. Microsoft will no longer be releasing security patches for this version of Windows, leaving all machines vulnerable to future exploits and vulnerabilities.

Business Impact

As Windows 10 is no longer receiving public security patches, this leaves the ATP Windows machines vulnerable to future vulnerabilities found in Windows 10. This could allow for compromise of the Windows machines that can no longer be updated.

Steps to Reproduce

Step 1: Log into the Windows machine

Step 2: Navigate to Settings > About to view current version of Windows

Remediation Strategies

Team-XX recommends the following:

1. Upgrade all Windows 10 machines to Windows 11 to continue receiving security updates from Microsoft
2. If a machine or software is incompatible from being upgraded to Windows 11, it is recommended to remove the outdated machine from the ATP

network and airgap the machine until a feasible way of converting to Windows 11 is found.

References

[Microsoft - Windows 10 End of Life](#)

I1: Internet Explorer Enabled

M0800 Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	Low		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	M1042: Disable or Remove Feature or Program	
	Mitigations		
Affected Scope			

Description

Internet Explorer is still installed and enabled on the **Domain Controller**. Internet Explorer has been deprecated by Microsoft and has stopped receiving all updates as of 2022.

Business Impact

Internet Explorer is an outdated and unsupported Microsoft program installed on the **Domain Controller**. While no current critical vulnerabilities are known for Internet Explorer, any newly discovered exploits will not receive security patches and would leave the machine open to attacks.

Steps to Reproduce

Step 1: Browse installed programs

Step 2: See Internet Explorer

Remediation Strategies

Team-XX recommends the following:

1. Uninstall Internet Explorer on all Windows machines to reduce the attack surface on the network.

References

[Microsoft - Internet Explorer End-Of-Life](#)

I1: Information Disclosure Through Error Message

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	N/A	
	Mitigations	M1054 – Application Isolation and Sandboxing M1051 - Update Software	
Affected Scope			

Description

The web application reveals sensitive information from its error messages revealing X. This information should not be publicly exposed as it provides attackers with information that could be used to do X.

Business Impact

Exposing detailed error messages increases the application's attack surface, and attackers can use this to perform targeted attacks on X. This can lead to unauthorized access, theft of sensitive information, and damage to APT's reputation.

Steps to Reproduce

Step 1: Enter X into the web application to trigger an error message.

Step 2: Observe the error message returned by the application and see that it reveals X.

Remediation Strategies

Team-XX recommends the following:

1. Hide error messages and display generic error messages that do not reveal internal technical details.
2. Disable debug mode to prevent the leakage of diagnostic information.

-
-
3. Audit the applications error handling regularly and keep all software components up to date.

References

[OWASP - Improper Error Handling](#)

[PortSwigger - Information disclosure vulnerabilities](#)

I1: Self-Signed HTTP Certificate on Public Site

Matrix Calculation		CVSS Score	Risk
Impact	Informational	N/A	Informational
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1587.003: Develop Capabilities - Digital Certificates	
	Mitigations	M1056: Pre-compromise	
Affected Scope			

Description

The web application on ... uses a self-signed certificate. Self-signing certificates for public applications is generally not recommended due to the increased possibility of error and the lack of browser trust due to not being a certificate authority. Also, if an attacker happens to find the certificate's private key, they can forge, modify, and decrypt network traffic.

Business Impact

At its worst, using self-signed certificates can enable attackers to perform adversary-in-the-middle attacks to steal client data, which can lead to fines and a loss of public reputation. Clients may also be unwilling to use ATP websites that have a self-signed certificate warning, impacting business operations and sales.

Steps to Reproduce

Step 1: Navigate to the website.

Step 2: Click on the padlock icon.

Step 3: Go to 'Connection is secure' and observe that the certificate is self-signed.

Remediations

Team-XX recommends the following:

1. Generate a valid certificate, either through a third-party certificate authority, or a self-hosted certificate trusted by the APT organization.
2. Replace the self-signed certificate with this certificate.

References

[Cloudflare - What is an SSL Certificate](#)